

Clase 167 — Acceso inicial: técnicas

Parte: **7 — Red Team y operaciones ofensivas** · Fuente: *MITRE ATT&CK Initial Access (TA0001) / RTFM v2* ⌚ Duración estimada: **100 min** · Nivel: **Avanzado**

Objetivo

Cubrir el abanico de técnicas de **acceso inicial** más allá del phishing: servicios expuestos, credenciales válidas, abuso de aplicaciones de cara a internet, drive-by y supply chain. El alumno aprenderá a elegir el vector según el objetivo y a establecer el primer punto de apoyo (foothold) de forma sigilosa en su laboratorio.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Enumerar** las técnicas de la táctica Initial Access de ATT&CK.
2. **Explotar** un servicio expuesto de laboratorio para obtener foothold.
3. **Usar** credenciales válidas (password spraying) de forma controlada.
4. **Evaluar** riesgos y sigilo de cada vector de entrada.
5. **Establecer** un foothold estable con el C2 previamente montado.

Temas

#	Tema	Por qué importa
1	External Remote Services (T1133)	VPN/RDP expuestos, vector muy común
2	Exploit Public-Facing App (T1190)	Webs y APIs vulnerables
3	Valid Accounts (T1078)	Credenciales filtradas/débiles
4	Password spraying	Un password contra muchos usuarios
5	Drive-by y supply chain	Vectores indirectos
6	Establecer foothold	Del acceso a la sesión C2
7	Sigilo del primer paso	No quemar la operación al entrar

Definiciones y características

- **External Remote Services (T1133)**: acceso vía servicios remotos expuestos (RDP, VPN, Citrix). Característica: no requiere malware, solo credenciales.
- **Exploit Public-Facing Application (T1190)**: explotar una vulnerabilidad en un servicio accesible. Característica: entrada directa sin interacción del usuario.
- **Valid Accounts (T1078)**: usar credenciales legítimas obtenidas. Característica: muy sigiloso, "parece" un login normal.

- **Password spraying:** probar 1–2 contraseñas comunes contra muchos usuarios. Característica: evita bloqueos por intentos.
- **Foothold:** primer punto de apoyo controlado en la red objetivo. Característica: base para pivotar y escalar.
- **Drive-by compromise (T1189):** comprometer al usuario al visitar un sitio. Característica: indirecto y oportunista.

Herramientas y preparación

- Máquinas de laboratorio con servicios expuestos deliberadamente (una web vulnerable, RDP, un VPN de lab).
- `nmap`, `ffuf` / `gobuster` para descubrir superficie; herramientas de la Parte 4 (web) y Parte 5 (explotación).
- Para spraying en AD: `kerbrute`, `NetExec (nxc)` contra el DC del lab.
- El C2 de las clases anteriores para convertir el acceso en sesión.

⚠ Todo se ejecuta contra sistemas de tu propio laboratorio o dentro del alcance autorizado. El password spraying puede bloquear cuentas: en engagements reales, coordínalo con la white cell y respeta las políticas de lockout.

Laboratorio guiado

1. **Mapea la superficie.** `nmap -sV -p- 10.10.10.0/24` en tu lab para localizar servicios expuestos (web, RDP, SMB, VPN).
2. **Explota un servicio público.** Toma la web vulnerable del lab y consigue ejecución (reutiliza técnicas de la Parte 4/5); confirma un shell.
3. **Enumera usuarios para spraying.** Contra el DC de laboratorio:

```
bash kerbrute userenum -d lab.local --dc 10.10.10.10 users.txt
```

4. **Password spraying controlado.** Una sola contraseña por ronda para evitar lockout:

```
bash nxc smb 10.10.10.10 -u users.txt -p '0to2026!' --continue-on-success
```

5. **Valida credenciales.** Con un par válido, comprueba acceso SMB/WinRM: `nxc winrm 10.10.10.20 -u user -p '0to2026!'`.
6. **Establece el foothold.** Entrega un implante C2 (Sliver) a la máquina comprometida y confirma la sesión a través del redirector.
7. **Documenta el vector** elegido, su ID ATT&CK y su nivel de sigilo relativo.

Ejercicios

1. Lista 6 técnicas de Initial Access con su ID de ATT&CK.
2. Explica por qué `Valid Accounts` es más sigiloso que explotar un servicio.
3. Diseña una campaña de password spraying que no bloquee cuentas (calcula el timing según la política de lockout).
4. Compara el riesgo de detección de `T1190` frente a `T1078`.
5. Consigue un foothold en el lab por dos vectores distintos y compáralos.

6. Investiga un caso real de acceso inicial por supply chain y resúmelo.

Reto verificable

Obtén un **foothold con sesión C2** en una máquina de tu laboratorio a través de un vector de Initial Access que **no** sea phishing, documentando la técnica ATT&CK usada. **Criterio de aceptación:** existe una sesión C2 activa originada por el vector elegido (servicio expuesto o credenciales válidas), presentas el ID ATT&CK correspondiente y explicas cómo evitaste bloqueos/ruido innecesario.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Cuentas bloqueadas masivamente	Spraying demasiado agresivo; una contraseña por ventana de lockout
El exploit no funciona	Versión distinta o WAF; confirma versión y ajusta el payload
Login válido pero sin acceso remoto	El usuario no tiene WinRM/RDP; prueba otro protocolo o usuario
Foothold se pierde al cerrar sesión	Falta persistencia; se añade en post-explotación
Detección inmediata	Vector ruidoso; elige credenciales válidas cuando el sigilo importa

Preguntas frecuentes

 **¿Cuál es el vector más común hoy?** Servicios remotos expuestos con credenciales válidas (a menudo filtradas) y explotación de aplicaciones públicas sin parchear compiten con el phishing por el primer puesto.

 **¿El password spraying es detectable?** Sí, genera muchos logins fallidos distribuidos; por eso se hace lento y con pocas contraseñas. Aún así, un SOC atento lo detecta.

 **¿Por qué preferir credenciales válidas?** Porque un login legítimo genera poca telemetría anómala frente a un exploit ruidoso; es el vector más "limpio" para el foothold.

Referencias

- MITRE ATT&CK — *Initial Access* (TA0001). <https://attack.mitre.org/tactics/TA0001/>
- NetExec (nxc). <https://github.com/Pennyw0rth/NetExec>
- kerbrute. <https://github.com/ropnop/kerbrute>
- Clark, B. — *RTFM: Red Team Field Manual* v2.

Siguiente clase

Clase 168 - Evasion de defensas: antivirus y EDR